

Architecture Update v2 — DrishtiMail Forensics

Client: Smart India Hackathon (problem statement SIH26106, AICTE — Cyber Security Cell)

Prepared by: fiftyfive technologies

Date: 2026-08-29

Status: Draft — additive integration of 8 confirmed features into the PRD v1 scope

Change type: nothing removed. Three merges, two module extractions, one new admin module. Supersedes the module list in PRD §5; PRD §4 and §6 remain intact.

1. Verification Status Convention

This document was prepared without network access. **Every third-party library, dataset, API and licence named below is marked NOT VERIFIED.** The verification column distinguishes three risk classes.

Status	Meaning	Action needed
LOCAL	Runs offline via an open-source library. No account, no quota, no network at runtime.	Confirm install and licence terms only.
SELF	Data the system generates itself (our own case / history database).	No external risk. Cold-start risk instead.
NOT VERIFIED	Needs an external account, quota, licence grant or redistribution right.	Confirm before it enters the plan. If it fails, the feature must degrade, not break.

Nothing below introduces a paid, proprietary, government-only or confidential dependency. Where the only candidate source is unverifiable, the feature is designed to work without it.

2. De-duplication Decisions

Four of the eight features overlap existing scope. Resolved as follows, so that no capability is built twice.

New feature	Overlaps with	Resolution
F1 Evidence Conflict Detector	M3 authentication-results cross-check	The cross-check stays in M3 — it compares two computations of the same thing. The Conflict Detector is a new stage comparing different evidence types against each other. Distinct scope; both kept.
F3 Quishing / QR Detection	M2 link and redirect analysis	Both move into a new M9 URL & Embedded Content Threat Engine . A QR code becomes a URL and joins the existing pipeline at the same entry point as a hyperlink. One extraction path, one redirect resolver, one typosquat checker.
F6 Campaign Memory + Shared Infrastructure Graph	M5 campaign clustering, property graph, pivot explorer	Same capability, already in scope. M5 is renamed to Investigation & Correlation Graph and absorbs the feature. Two additions only: template / structural fingerprinting, and the first-contact index.
F7 Evidence Ledger + Verifiable Custody	M7 chain of custody, hashing, verification tool	Same capability. M7 is renamed to Evidence Integrity Layer. One addition: every finding — not just every message — now carries a back-reference to its source artifact.
F8 Explainable Threat Scoring	M2 calibrated 0–100 score	Split. M2 now emits a model probability, classification and feature attribution. The final 0–100 case score is aggregated in a new M11 from all module signals, of which M2’s probability is one input. Without this split the score cannot include header, URL, QR, infrastructure or conflict evidence.

3. Final Module List

Existing identifiers are preserved. Three modules renamed, four added.

ID	Module	Status	New features carried
M1	Ingestion & Normalisation	unchanged	—
M2	Detection Engine (NLP/ML)	narrowed	link / QR / attachment work moves to M9; scoring moves to M11
M3	Header & Protocol Analysis	extended	F5 Authentication Semantics
M4	Origin Traceability & Location	unchanged	feeds F1 and F8

ID	Module	Status	New features carried
M5	Investigation & Correlation Graph <i>(was Identity Correlation & Attribution)</i>	merged	F6 Campaign Memory + Shared Infrastructure; F4 First-Contact Baseline
M6	Alerting, Dashboard & Reporting	extended	user-interface surfaces for F1, F5, F7 and F8
M7	Evidence Integrity Layer <i>(was Privacy, Legal & Evidence Integrity)</i>	merged	F7 Evidence Ledger + Verifiable Custody
M8	Administration	extended	hosts the model registry that M12 writes to
M9	URL & Embedded Content Threat Engine	new (extracted)	F3 Quishing / QR Detection
M10	Evidence Conflict Detector	new	F1
M11	Explainable Threat Scoring	new (extracted)	F8
M12	ML Evaluation & Model Validation	new, admin-only	F2 — deliberately off the per-email path

4. Integrated Pipeline

Per-email flow. Each stage writes its outputs and its evidence references to the ledger as it completes.

Stage	Module	What happens
1	M1 Ingestion	.EML file, bulk archive, pasted headers, submission endpoint or mailbox poll. Structure parse, SHA-256 at ingest, write-once original, deduplication.
2	M3 Header & Protocol	Relay chain, trust boundary, SPF / DKIM / DMARC with alignment, and F5 authentication semantics — what each result does and does not establish.
3	M9 URL & Embedded Content	Hyperlink extraction, F3 QR decode across body, inline images and attachments, and attachment static analysis — all converging on one URL set, then redirect expansion, display-versus-destination, typosquatting and threat-feed lookup.
4	M2 Detection Engine	Six-class classification, social-engineering cues, payment-fraud sub-patterns, concealment, thread-hijack, multilingual body analysis. Emits model probability plus feature attribution.
5	M10 Evidence Conflict	F1 — compares M3, M9, M2 and M4 outputs against each other and emits named contradictions with both sides quoted.
6	M4 Origin Traceability	Earliest-reliable-origin selection with justification, geolocation, network operator, infrastructure type, domain registration intelligence.
7	M5 Investigation & Correlation Graph	Indicator extraction, campaign clustering, shared-infrastructure edges, and F4 first-contact baseline — has this indicator ever been seen here before?
8	M11 Explainable Threat Scoring	F8 — weighted aggregation of every signal above, with per-signal contribution and a confidence band.
9	M7 Evidence Integrity Layer	F7 — finding-to-evidence links, custody entries, hash-chained append-only ledger.
10	M6 Alerting, Dashboard & Reporting	Queue, detail view, alerts, dashboards, forensic report and admissibility certificate.

Off this path, administrator only: M12 ML Evaluation Dashboard. It runs against a frozen held-out test set on demand, writes metrics to the M8 model registry, and never touches an individual email's analysis.

Ordering rationale. Conflict detection sits at stage 5 because it needs authentication (2), URL and QR (3) and AI (4) results, but must run before scoring (8) so that a detected contradiction can suppress or discount a signal rather than have the score absorb both sides of it. Correlation (7) sits after geolocation (6) because shared-infrastructure edges are built on resolved network and operator data, not raw addresses alone.

5. Feature Specifications

5.1 F1 — Evidence Conflict Detector (M10)

How it works. A deterministic rule engine, not a model. Each upstream module emits typed claims into a normalised claim set of claim type, value, source module, confidence and evidence reference. Conflict rules are pairwise predicates over that set. Every rule that fires produces a named conflict with both sides quoted and a plain-language explanation of what the contradiction means. The starting rule set below should be expected to grow to roughly twenty-five entries.

Conflict	Left evidence	Right evidence	Investigative meaning
Authenticated but misaligned	SPF or DKIM pass	From domain differs from authenticated domain	The message is genuinely from somewhere — just not from who it claims
Reply-path divergence	From domain	Reply-To or Return-Path domain	Replies leave the claimed organisation
Authentication pass versus content risk	DMARC pass	M2 high phishing probability	Likely a compromised legitimate account rather than spoofing
Authentication fail versus benign content	SPF fail	M2 low probability with a valid forwarding chain	Probably a mailing list, not an attack
Display versus destination	Anchor text domain	Resolved final URL host	Classic link disguise
QR versus body divergence	Decoded QR host	All hyperlink hosts in the body	Payload deliberately kept out of the text
Geography versus claim	M4 origin country and operator	Claimed sending organisation	Registrar in one place, origin in another
Header versus relay timing	Date header	Earliest reliable hop timestamp	Fabricated or replayed header
Feed versus baseline	Threat feed reports known-bad	F4 reports never seen here	Known campaign, first appearance at this institution

Data required. None external — inputs are entirely internal module outputs. **ML training data:** no. **Verification:** LOCAL.

Student-buildable: yes. This is the highest value-per-line feature in the whole addition — roughly a day for the engine, then ongoing work on rule content. **Demonstrable:** yes, and it is the strongest single demo moment. A crafted .eml with DKIM passing on a lookalike domain produces “authenticated, but not by who it claims” — precisely the semantic gap named in PRD §1.

5.2 F2 — ML Evaluation Dashboard (M12)

How it works. An offline evaluation script runs the current model version against a frozen held-out split and writes a metrics artifact containing precision, recall, F1, false-positive rate, confusion matrix, per-class breakdown, test-set size, class balance, split hash and evaluation timestamp. The dashboard **only reads that artifact**. It computes nothing at view time and displays nothing it has not been given.

Hard rule — no invented numbers. If no evaluation artifact exists for the loaded model version, the dashboard displays “No evaluation on record for this model version” and an empty state. Not a placeholder, not a sample number, not a rounded guess. Any figure shown in a demonstration must be traceable to a committed artifact file and a committed split. This is enforced in code by having the dashboard component accept no default values.

Data required. A labelled held-out test set. This is the project's single largest data risk and is already PRD Open Question 3.

Candidate source	Type	Status
Public phishing and ham corpora (for example the SpamAssassin public corpus, the Nazario phishing collection, Enron ham, published phishing-email datasets)	free, downloadable	NOT VERIFIED — licence, redistribution rights in a demonstration context, and current availability are all unconfirmed
Institution-donated mail	private	NOT VERIFIED — PRD §9 already flags this as unavailable
Team-authored synthetic phishing set	self-produced	SELF — legitimate for demonstrating the dashboard, but it must be labelled “synthetic evaluation set” on screen and never presented as evidence of generalisation
Metrics computation (standard open-source classification report and confusion matrix utilities)	library	LOCAL

Known bias to disclose on the dashboard itself. Public corpora are era- and encoding-biased, and no non-English phishing corpus has been identified — so the multilingual claim in M2 currently has no measurable evidence behind it. State this on the panel rather than letting a reviewer discover it.

ML training data: yes — and train/test split discipline is mandatory. The test split must be frozen and hashed before any tuning. **Student-buildable:** yes; the dashboard is trivial, sourcing defensible data is the hard part. **Demonstrable:** yes, but

demonstrate it as “here is how we validate, here is our real number on this stated corpus, here is what that corpus does not cover.” Judges reward stated limitations and punish suspiciously round accuracy figures.

5.3 F3 — Quishing / QR-Code Detection (M9)

How it works. Three extraction surfaces, one decoder, then straight into the existing URL pipeline.

1. **Inline and referenced images** — MIME parts of image type, plus content-ID referenced parts and base64 data URIs in HTML bodies.
2. **Image attachments** — the same decoder path.
3. **Document attachments** — PDF pages rasterised to images and then decoded; for office documents, embedded media extracted from the container archive and then decoded.

Decode with an open-source symbol reader. Pre-processing matters more than decoder choice: grayscale, upscale, adaptive threshold, and try all four rotations before declaring failure.

The output URL is normalised and **injected into the same M9 queue as hyperlinks** — same redirect expansion, same typosquatting check, same threat-feed lookup, same display-versus-destination logic. Provenance is tagged as QR-sourced so that M10 can detect body-versus-QR divergence and M11 can weight it.

Failure is a signal, not a gap. If image analysis finds a high-contrast square finder pattern but decoding fails, emit “QR present, undecodable” rather than silently reporting no QR. An unreadable QR code in a payment email is itself worth flagging.

Need	Candidate source	Status
QR decoding	ZBar bindings, a zxing port, or the OpenCV QR detector	LOCAL — NOT VERIFIED on licence and install; ZBar is LGPL, check before bundling
Image handling	Pillow, OpenCV	LOCAL
PDF rasterisation	PyMuPDF, or pdf2image with Poppler	LOCAL — NOT VERIFIED ; PyMuPDF is AGPL, which matters if the prototype is distributed
Test QR images	Generate your own with a QR-encoding library	SELF

ML training data: no — classical computer vision, deterministic. **Student-buildable:** yes, one of the easiest of the eight.

Demonstrable: excellent. Generate a QR code pointing at a shortener that redirects to a typosquat domain — one artifact demonstrates QR decode, redirect expansion and typosquatting on a single screen. Prepare the redirect chain offline in the cached demo fixture; do not depend on a live shortener resolving during the demonstration.

5.4 F4 — First-Contact Baseline (M5)

How it works. Every extracted indicator — sender address, From domain, envelope domain, origin address, network range, operator, URL host, file hash, structural fingerprint — is checked against the institution's own historical index before being written to it. Each returns first-seen timestamp, sighting count, distinct case count, and a derived familiarity band: first-contact, rare (fewer than five sightings) or established.

Guard rails, enforced in code and not in policy:

- First contact contributes a **capped, low-weight** increment to the M11 score. Nominal ceiling: 8 of 100 across all first-contact signals combined, tunable in M8.
- First contact **can never alone** move a message above the escalation threshold. Implemented as an assertion in M11: if first-contact signals are removed and the score falls below threshold, the verdict is downgraded and the reason recorded.
- Interface copy is fixed: “Not previously seen in this institution's records — novelty, not evidence of maliciousness.”
- The inverse must also be visible: an established indicator is not evidence of safety, since compromised legitimate accounts are established by definition.

Cold start. With an empty history everything is first contact and the signal is worthless. Two mitigations: suppress the signal entirely until the index holds a configurable minimum volume (default one thousand messages); and for the demonstration, pre-ingest the corpus so that history genuinely exists — and say on stage that you did.

Need	Candidate source	Status
Historical indicator index	Our own database, indexed on indicator value and type	SELF
Bootstrap volume	Pre-ingested demonstration corpus	SELF, subject to the corpus licence question raised under F2

ML training data: no. **Student-buildable:** yes — it is an indexed lookup plus a rule. The engineering is easy; the discipline around the guard rails is what makes it correct. **Demonstrable:** yes, but only if history is seeded first. Show the same infrastructure appearing in message one as first contact and in message three as “seen twice before, case CASE-0002”.

5.5 F5 — Authentication Semantics Panel (M3 and M6)

How it works. A lookup table over the result tuple of SPF result, DKIM result, DMARC result, SPF alignment, DKIM alignment and whether a forwarding chain was detected. Each cell carries three fixed pieces of prose, authored once by the team: what the outcome **establishes**; what it **does not establish** that a reader might wrongly infer; and its **effect on this investigation**.

Worked example — SPF pass, DKIM pass, DMARC pass, alignment failure on a lookalike domain:

Establishes — the sending server was authorised to send for the lookalike domain, and the message was not altered in transit.

Does not establish — that the sender is your Registrar. Authentication proves control of the sending domain, never the honesty of the person controlling it. An attacker who registers a domain can pass all three checks on it within minutes.

Effect — treat the authentication result as confirming which infrastructure sent this, not whether to trust it. The lookalike finding from M9 is the load-bearing evidence here, not the authentication result.

Second worked example — SPF failure on a forwarded message: establishes that the last relay was not authorised for the original domain; does not establish spoofing, because forwarding breaks SPF by design; effect — check the forwarding chain before scoring this as a failure.

Data required. None external — inputs are M3’s existing outputs. The prose is authored by the team from the published protocol specifications for SPF, DKIM and DMARC, which the team should read directly rather than trust a summary of. **ML training data:** no. **Verification:** LOCAL.

Student-buildable: yes — half a day of engineering plus a day of careful writing. **Demonstrable:** yes. This is the feature that most directly answers the “cannot explain” gap in PRD §1, and the one that makes a non-technical judge understand the product.

5.6 F6 — Campaign Memory and Shared Infrastructure Graph (M5)

How it works. A property graph over nodes for email, campaign, domain, address, network operator, URL, file hash, sender address and structural fingerprint, with typed edges for sent-from, resolves-to, hosted-on, links-to, shares-template and member-of.

Campaign membership is decided by an explainable scoring function over shared indicators, not by opaque clustering:

- Shared origin address or network range — **strong**
- Shared operator alone — **weak**. Shared hosting is not shared actor, and the interface must say so.
- Shared URL host, or a shared registrar and creation-window pair — **strong**
- Shared file hash — **very strong**
- Structural fingerprint similarity above threshold — **strong**
- Shared subject or display-name pattern — **moderate**

Structural fingerprinting is the one genuinely new component: strip text content from the HTML, keep the tag skeleton, attribute names and layout order, then compute a similarity signature over that skeleton. This catches the same phishing kit reused with different wording and different domains — which is precisely how campaign reuse actually looks. Text-only similarity misses it.

Every campaign edge must be clickable through to its justifying evidence, and every campaign view must state its shared indicators explicitly. A campaign assertion with no visible shared indicator is a defect. The attribution boundary is unchanged

and non-negotiable: infrastructure clustering only, no identity assertion ever, per PRD §5 Out.

Need	Candidate source	Status
Graph storage	A relational database with recursive queries (simplest), a community-edition graph database, or an in-memory graph library at prototype scale	LOCAL — NOT VERIFIED on graph-database community licence terms at scale; the relational option is the safe default
Similarity hashing	MinHash or SimHash libraries, or hand-rolled shingling	LOCAL
Historical corpus	Our own ingested mail	SELF
Threat-feed enrichment on nodes	The existing M5 feed integration	NOT VERIFIED — already PRD Open Question 2. The graph must function with zero feed enrichment.

ML training data: no. Threshold tuning on a small labelled set is helpful but not required. **Student-buildable:** yes at prototype scale — do not attempt a distributed graph store. A relational store plus an in-memory traversal library will carry an SIH demonstration comfortably. **Demonstrable:** yes, and visually the most impressive. Ingest three or four related messages and show the graph assembling itself around one shared address.

5.7 F7 — Evidence Ledger and Verifiable Custody (M7)

How it works. Three layers, all at zero cost.

Layer 1 — evidence references. Every finding produced by any module carries a finding identifier, case identifier, source module, evidence reference, extraction timestamp and artifact hash, where the evidence reference points to an exact location in the preserved original — header name, MIME part index, byte offset. A finding with no evidence reference cannot be written, enforced by a database constraint rather than by convention. This is what makes the report defensible: every sentence traces to a byte in the original message.

Layer 2 — hash-chained ledger. An append-only table in which each row stores the previous row's hash and its own hash computed over that value concatenated with its content. Any retroactive edit breaks the chain at that point and at every point after it, and the break is detectable by recomputing the chain. Database permissions grant insert only — no update, no delete — to the application role.

Layer 3 — periodic root. At a fixed interval, compute a Merkle root over the ledger rows added since the last root and record it. Export it with the report. This gives a compact value that a third party can hold, and it directly addresses **PRD Open Question 4**: a hash-chained ledger with an exported Merkle root achieves tamper-evidence at zero cost and requires no distributed ledger, no external anchoring service and no budget. External anchoring stays optional and is marked **NOT VERIFIED** — the MVP must not depend on it.

Verification tool. A standalone script shipped alongside the exported report, which takes the report bundle and recomputes the original message hash, each finding's artifact hash, and the ledger chain, printing pass or fail per item. It must run with no access to the running system — that is the entire point.

Need	Candidate source	Status
Hashing	Standard-library SHA-256	LOCAL
Append-only storage	Relational table with role permissions and a trigger blocking update and delete	LOCAL
Merkle tree	Roughly forty lines, hand-rolled	LOCAL
External anchoring	Any public anchoring service	NOT VERIFIED — explicitly out of the MVP

ML training data: no. **Student-buildable:** yes, entirely — no exotic dependencies. **Demonstrable:** yes, and it is the single most convincing thirty seconds available. Export a report, open it in a hex editor, change one byte, re-run the verifier and watch it fail; restore the byte and watch it pass. This satisfies the PRD §6 M7 acceptance criterion verbatim.

5.8 F8 — Explainable Threat Scoring (M11)

How it works. A transparent weighted-additive model over normalised signals. No opaque aggregation — the requirement is explanation, and an additive model explains itself. The score is the sum of each signal's weight multiplied by its strength and by any conflict adjustment, clamped to the range 0 to 100.

Signal family	Source	Weight ceiling
Authentication failure or misalignment	M3	20
Sender and display-name mismatch, lookalike domain	M2 and M9	20
URL risk — redirect chains, display mismatch, typosquatting, feed hit	M9	20
QR-borne URL risk	M9, QR-sourced	10
Attachment risk	M9	15
AI content indicators — social engineering, fraud pattern, class probability	M2	25
Infrastructure risk — domain age, hosting type, geographic anomaly	M4	15
Campaign and known-bad correlation	M5	15
First-contact novelty	M5 / F4	8, hard-capped
Evidence conflict adjustment	M10	plus or minus 15

Ceilings intentionally sum above 100 — the clamp is doing real work, and no single family can reach the escalation threshold alone.

Conflict adjustment is what makes this more than a sum. When M10 reports a DMARC pass alongside a high AI probability, the scorer does not add both naively; it applies the conflict rule's stated adjustment and records “authentication signal discounted — contradicted by content analysis, consistent with account compromise rather than spoofing.”

Mandatory output contract. Every score renders with all four of the following:

1. Ranked per-signal contributions with their actual point values, summing visibly to the total.
2. A confidence band, not a point value.
3. Fixed disclaimer language: “This is a weighted assessment of observable evidence, not a determination of fact. Review the contributing signals before acting.”
4. A link from each contribution to its M7 evidence reference.

Never expressed as certainty. No “100% malicious”, no “confirmed phishing”. Verdict labels are Low, Elevated, High and Critical — assessments, not conclusions. A score of 100 means “every signal we measure fired”, not “certainly malicious”.

Data required. None external; all inputs internal. Weight calibration uses the F2 held-out split, and the calibration date should be shown in the M8 registry. **ML training data:** no for the scorer itself; the M2 probability it consumes does require training data. **Student-buildable:** yes. **Demonstrable:** yes — this is the closing screen of the demonstration, because it visibly pulls together every prior stage.

6. Feature-to-Data Mapping

#	Feature	Mod.	External data	Provider	ML data	Build	Demo	Verification
F1	Evidence Conflict Detector	M10	none	internal	no	yes	yes, strong	LOCAL
F2	ML Evaluation Dashboard	M12	labelled held-out test set	public corpora or synthetic	yes	yes	yes, with caveats	NOT VERIFIED
F3	Quishing / QR Detection	M9	none at runtime	open-source symbol reader	no	yes	yes, strong	LOCAL (licence NOT VERIFIED)
F4	First-Contact Baseline	M5	own history database	self	no	yes	yes, if seeded	SELF
F5	Authentication Semantics	M3 / M6	none	spec-derived prose	no	yes	yes, strong	LOCAL

#	Feature	Mod.	External data	Provider	ML data	Build	Demo	Verification
F6	Campaign and Infrastructure Graph	M5	own history; feeds optional	self plus local store	no	yes	yes, strong	SELF / LOCAL
F7	Evidence Ledger	M7	none	standard library plus database	no	yes	yes, strongest	LOCAL
F8	Explainable Scoring	M11	none	internal	no (consumes M2)	yes	yes	LOCAL

Seven of the eight features have no external data dependency at all. Only F2 does, and it inherits a risk the PRD already carries. That is a deliberately defensive property of this integration.

7. MVP Priority

Ordered for a build by a six-member team. PRD Open Question 5 already questions whether full scope is deliverable; this ordering assumes it is not, and sequences accordingly.

Tier	Order	Feature	Why here
P0 build first; the demonstration depends on these	1	F7 Evidence Ledger (M7)	Everything else writes into it, so it must exist first
	2	F5 Authentication Semantics (M3)	Cheapest to build, highest explanatory value
	3	F3 QR Detection into the existing URL engine (M9)	Self-contained, no external dependency, strong on screen
	4	F8 Explainable Scoring (M11)	Needs at least F5 and the M9 URL signals before it is meaningful
	5	F1 Evidence Conflict Detector (M10)	Needs F5 and the M2 outputs to compare
P1 build second; materially strengthens the demonstration	6	F6 Campaign Graph at prototype scale (M5)	High demonstration value, moderate build cost, no external dependency
	7	F4 First-Contact Baseline (M5)	Rides on the same index F6 builds, so it is nearly free once F6 exists
P2 build last; be honest about the limitation	8	F2 ML Evaluation Dashboard (M12)	The dashboard is a day's work; the data question behind it may not resolve at all. Build the dashboard and the evaluation script, run it against whatever defensible set exists, and present the limitation openly rather than deferring the whole feature.

Dependency note. F8 cannot be built before F5, F3 and M3 emit signals — a scorer with two inputs demonstrates worse than no scorer at all. F4 cannot be demonstrated before the F6 index exists. F1's rule set grows with every module completed, so leave its rule table open until the freeze.

8. Demonstration Workflow (3–5 minutes)

Everything cached and offline. Per PRD §9, no live external call may sit on the demonstration path — including the QR redirect chain and any feed lookup. Seed the history index with forty to sixty pre-ingested messages before starting, so that F4 and F6 have something real to say.

Time	Action	Feature shown
0:00–0:20	Frame the gap. “Our institution can block this mail. It cannot explain it, trace it, or hand it to a police cell. Here is a spoofed Registrar invoice.” Upload the .eml.	M1
0:20–0:45	The hash appears at ingest. “Everything after this point is provably derived from this exact file.”	F7
0:45–1:25	Authentication Semantics panel. SPF, DKIM and DMARC all pass — then read the panel aloud: establishes, does not establish, effect. “It is authenticated. It is authenticated by the attacker.”	F5

Time	Action	Feature shown
1:25–2:05	URL and Embedded Content engine. No suspicious links in the text — but there is a QR code in the invoice image. Decode it live on screen, expand its redirect chain, land on the typosquat domain.	F3
2:05–2:35	Evidence Conflict Detector. Named conflicts appear — authenticated but misaligned, QR versus body divergence — each quoting both sides.	F1
2:35–3:15	Correlation graph. Same origin network range as two messages from last week; same structural fingerprint, different wording, different domain. The campaign forms on screen with its shared indicators listed. First-contact panel: the domain is new here, the infrastructure is not.	F6, F4
3:15–3:45	Explainable score. 87, Critical. Every contributing signal listed with its point value, summing on screen. Point at the disclaimer and say it aloud: this is an assessment, not a determination.	F8
3:45–4:25	Export the forensic report. Open the exported file, change one byte, run the standalone verifier — FAIL . Restore the byte, re-run — PASS . “This is the difference between a finding and evidence.”	F7
4:25–5:00	Close on the administrator view. ML Evaluation dashboard: real precision, recall and F1 on our stated held-out set, with the test-set size and the corpus limitation shown on the same screen. “We are telling you what we measured and what we did not.”	F2

Why this order. It runs the pipeline in its actual sequence, so the architecture explains itself without a slide. It ends on the two things judges cannot get from any other team's demonstration: tamper-evident evidence, and a team that states its own measurement limits instead of quoting a suspiciously round accuracy figure.

Fallback. If the graph render is slow, F6 and F4 collapse into a static screenshot and the time goes to the F7 byte-flip, which is the moment that lands hardest.

9. Effect on Existing Open Questions

PRD question	Change
2 — threat-feed quota	Reduced in severity. F6's graph and F4's baseline both function on self-generated data with zero feed calls. Feed enrichment becomes an enhancement rather than a dependency.
3 — training data	Unchanged, and now more visible. F2 surfaces this gap on a dashboard rather than hiding it inside a metrics claim. That is an improvement in honesty, not a resolution.
4 — zero-cost anchoring	Resolved for the MVP. A hash-chained append-only ledger with an exported Merkle root gives tamper-evidence at zero cost with no external service. External anchoring is downgraded to optional.
5 — scope deliverability	Worsened. Eight features added to a scope already flagged as questionable for six people. The P0 / P1 / P2 ordering in section 7 is the mitigation: P0 alone produces a coherent, demonstrable, defensible system.

10. Open Questions Added by This Update

1. What is the minimum history volume before the F4 first-contact signal is trusted rather than suppressed? One thousand messages is proposed as a default and needs a decision.
2. Which QR decoder, given the licence question? ZBar is LGPL and PyMuPDF is AGPL — this matters if the prototype is distributed or open-sourced.
3. Who authors the F5 semantics prose? It is the most user-visible text in the product and it must be technically exact. Assign one named person, not “the team”.
4. Does the F8 conflict adjustment need its own calibration set, or is expert judgement on the weights acceptable for the prototype?
5. What is the retention rule for the F6 graph and the F4 index, given the configurable per-class retention in PRD §5? Indicator history is precisely the data that is most useful when kept longest and most sensitive when kept at all.